EVIDENCE PACK

AcmeLIMS - Wave 1

Wave 1 - Quick wins

Generated	2026-10-13T07:04:03+00:00	**Target cloud**	AWS
Wave window	2026-11-24 to 2026-12-22	**Tasks in wave**	4
Components	36	**Regulated tables**	14
Generated by	ModernRx	**Status**	**DRAFT - requires QA review**

Draft generated by ModernRx to support - not replace - the organization's validation process. Every section requires review and approval by qualified personnel before use. ModernRx is a decision-support tool: it does not validate software, and its output is not evidence of validation.

Contents

1	System description
2	Intended use and GxP impact
3	Risk-based assurance plan (CSA)
4	Characterisation tests
5	Shadow / differential testing plan
6	Data migration checks
7	Traceability matrix
8	Rollback plan
9	Cloud supplier oversight checklist

1. System description

Property	Value
Lines of code	2,090
Primary language	Java
Components analysed	36
Database tables	15 (14 regulated)
HTTP endpoints	22
Knowledge-graph size	486 nodes, 888 relationships
Runtime use cases observed	11

Regulated tables

AUDIT_TRAIL, BATCH, CAPA, CHAIN_OF_CUSTODY, DEVIATION, INSTRUMENT_IMPORT, LIMS_ROLE, LIMS_USER, RESULT, RESULT_SIGNATURE, SAMPLE, STABILITY_STUDY, TEST_SPECIFICATION, USER_ROLE

Business use cases captured from runtime traces

- Admin creates analyst
- Enter OOS result
- Enter result
- Instrument file import
- Nightly stability pull
- OOS summary dashboard
- Print certificate of analysis
- Register sample
- Release batch
- Review and sign result
- Trend report

End-of-life dependencies

Library	Version	Why it matters
spring-boot-starter-parent	2.3.12.RELEASE	Spring Boot 2.x - OSS support ended Nov 2023
h2	1.4.200	H2 1.x - console RCE (CVE-2021-42392); not a production DB
log4j	1.2.17	Log4j 1.x - end of life Aug 2015, unpatched CVEs
commons-collections	3.2.1	commons-collections 3.x - deserialisation RCE
junit	4.12	JUnit 4 - superseded by JUnit 5 (Jupiter)
jdk	1.8	Java 1.8 is past its free public-update window

2. Intended use and GxP impact

7 component(s) in scope: 0 HIGH, 3 MEDIUM, 4 LOW. Under a risk-based approach 0 of 7 (0%) require scripted testing with independent review; the remainder are covered by exploratory testing with recorded results or by automated and vendor evidence.

Intended use per component

Component	Tier	Intended use
ProductBatch	**MEDIUM**	ProductBatch provides supporting logic with no GxP data path.
TestResult	**MEDIUM**	TestResult provides supporting logic with no GxP data path.
DateHelper	**MEDIUM**	DateHelper stamps records with the time of the recorded event.
BatchMapper	**LOW**	BatchMapper provides supporting logic with no GxP data path.
TestResultMapper	**LOW**	TestResultMapper provides supporting logic with no GxP data path.
LegacyExcelExporter	**LOW**	LegacyExcelExporter provides supporting logic with no GxP data path.
StringHelper	**LOW**	StringHelper provides supporting logic with no GxP data path.

Compliance gaps identified in the current system

[HIGH] Audit trail cannot record a reason for change

Reference: 21 CFR 11.10(e); EU GMP Annex 11 §9

The audit-trail table has no column for the reason for change. Part 11 requires audit trails to record the reason where it is a predicate-rule requirement, and Annex 11 expects changes to GxP data to be justified. Reason is currently appended into a value column as free text, which is not queryable and not reportable.

Remediation: Add a REASON column (and a controlled reason-code list) to the audit table, require it on every change to a GxP record, and backfill or annotate historic rows. This is a data-model change, so it needs a data migration plan and re-validation of the audit-trail report.

Evidence: AUDIT_TRAIL

[HIGH] Database schema is altered automatically at startup

Reference: EU GMP Annex 11 §10 (change control); 21 CFR 11.10(a)

The ORM is configured to update the database schema on application start. The structure holding GxP records can therefore change without a change-control record, a review, or a migration script, and the change is invisible to the audit trail.

Remediation: Set the schema generation to validate-only, manage every structural change through versioned migration scripts under change control, and verify the schema as part of installation qualification.

Evidence: ddl-auto

[HIGH] Database console exposed in the running application

Reference: Annex 11 §12; data-integrity expectation

A web database console is enabled. It permits direct, unaudited modification of GxP data, which breaks the audit trail entirely.

Remediation: Disable the console in every environment above development and prove it is off as part of installation qualification.

Evidence: enabled

[HIGH] GxP timestamps come from the application server clock

Reference: 21 CFR 11.10(e); EU GMP Annex 11 §9

Records are stamped with the application server's local time. Across multiple instances - which is exactly what a cloud migration introduces - clock drift and timezone differences make the sequence of GxP events unreliable, and contemporaneousness cannot be demonstrated.

Remediation: Take all GxP timestamps from a single authoritative source (the database clock or an NTP-synchronised UTC service), store them as UTC with an explicit offset, and document the time-synchronisation control.

Evidence: createUser, recordChange, applyDisposition, importFile, recordFailedImport, registerGeneratedCoa

[HIGH] GxP record is modified without an audit-trail entry

Reference: 21 CFR 11.10(e)

A write path to a regulated table does not reach the audit-trail service, so the change is not recorded.

Remediation: Route the write through the audit-trail service, or add database-level triggers, and add a test that fails when a GxP write has no audit row.

Evidence: recordFailedImport, purgeStaleImports

[HIGH] Credentials stored in configuration files

Reference: Annex 11 §12.4; general data-security expectation

Database or service credentials are present in configuration committed with the application.

Remediation: Move every credential to a managed secrets service, inject at runtime, and rotate anything that has been in version control.

Evidence: password, password

[HIGH] Shared administrator credential in configuration

Reference: 21 CFR 11.10(d),(g); Annex 11 §12

An administrator username and password are stored in a configuration file and compared in plain text. A shared account means actions cannot be attributed to an individual, and a credential in a config file is readable by anyone with repository or filesystem access.

Remediation: Remove the credential from configuration, move to named individual accounts with role-based access, and keep any break-glass account in a secrets manager with check-out logging.

Evidence: password

[MEDIUM] Audit trail identifies the actor by free text

Reference: 21 CFR 11.10(d); ALCOA++ Attributable

The audit trail stores the acting user as a plain string rather than a reference to the user table, so a renamed or deleted account breaks attributability of historic records.

Remediation: Store the immutable user id alongside the display name, and never delete user rows - deactivate them.

Evidence: CHANGED_BY

[MEDIUM] GxP data arrives over a host filesystem path

Reference: Annex 11 §4.8, §5 (data transfer checks)

Instrument data is read from an absolute local or UNC path. The transfer has no checksum or completeness check, and the path cannot be reached from a container or managed runtime.

Remediation: Replace with object storage or a managed file-transfer service, add a verified-transfer check (checksum plus row count) and record the transfer in the audit trail.

Evidence: importPendingFiles, parseCsv, archive, inbox, archive, dir

[LOW] User identity carried in a server-side session

Reference: n/a - architectural readiness, not a compliance gap

The acting user is read from the servlet session. Horizontal scaling needs sticky sessions or a shared session store, and a lost session can leave a GxP write without an attributable actor.

Remediation: Carry identity in a signed token validated per request, and resolve the actor at the point of the write.

Evidence: create, assignRole, release, reject, enter, correct

3. Risk-based assurance plan (CSA)

Computer Software Assurance scales the assurance effort to risk. Of the 7 component(s) in this wave, 0 require scripted testing with independent review, 3 are covered by unscripted testing with recorded results, and 4 by automated and vendor evidence.

MEDIUM tier - Unscripted / exploratory testing with recorded results (3 component(s))

These components read GxP data or enforce access control. A failure is serious but does not directly alter a regulated record, so CSA permits a lighter, more efficient approach.

Activities:

- Exploratory testing of the main flows against documented intended use
- Recorded results for each session: who tested, what was exercised, what happened
- Verification that read models agree with the source of record
- Access-control testing: each role sees and does only what it should
- Automated regression suite execution

Evidence to retain:

- Test session records with tester, date, scope and outcome
- Automated test run output retained as system-generated evidence
- Reconciliation of read-model output against source records

Reviewer: System owner, with QA review of the summary | Approval: System owner approval; QA notified

LOW tier - Vendor and automated evidence with ad-hoc testing (4 component(s))

No GxP data path. CSA explicitly permits leveraging vendor documentation and automated evidence here, and spending the saved effort on the high-risk components instead.

Activities:

- Automated build, unit and integration tests in the qualified pipeline
- Smoke testing after deployment
- Vendor/platform documentation reviewed and retained for managed services

Evidence to retain:

- Pipeline run records (build, test, deploy) retained as system-generated evidence
- Smoke-test output
- Vendor qualification documents for any managed service used

Reviewer: Technical lead | Approval: Technical lead approval; no QA gate

4. Characterisation tests

5 of 7 class(es) have a generated characterisation test, including 0 of 0 HIGH-tier class(es). These are skeletons with the expected values left as placeholders: the values must be captured from the legacy system, because only the legacy system knows what the current behaviour is. Method selection is driven by observed runtime calls, so the busiest and most critical paths are covered first.

Artefact	Kind	Tier	Why
DateHelperCharacterisationTest	unit	**MEDIUM**	DateHelper is GxP MEDIUM; 254 observed calls make its current behaviour the baseline the migration must preserve.
StringHelperCharacterisationTest	unit	**LOW**	StringHelper is GxP LOW; 326 observed calls make its current behaviour the baseline the migration must preserve.
BatchMapperCharacterisationTest	unit	**LOW**	BatchMapper is GxP LOW; 0 observed calls make its current behaviour the baseline the migration must preserve.
TestResultMapperCharacterisationTest	unit	**LOW**	TestResultMapper is GxP LOW; 0 observed calls make its current behaviour the baseline the migration must preserve.
LegacyExcelExporterCharacterisationTest	unit	**LOW**	LegacyExcelExporter is GxP LOW; 0 observed calls make its current behaviour the baseline the migration must preserve.

5. Shadow / differential testing plan

Run the legacy and modernized components side by side. Mirror a copy of each production request to the new service, compare the responses field by field, and report every mismatch. The legacy system remains the system of record throughout, so a mismatch is a finding rather than a deviation.

Duration: Minimum two full business cycles per wave, and at least one month-end and one batch-release cycle for any HIGH-tier component.

Comparison rules

- Response payloads compared field by field; a differing field is a finding.
- Timestamps compared for ordering and timezone, not exact equality - clock source differences are expected and are themselves a finding to resolve.
- Generated identifiers excluded from equality but checked for uniqueness and format.
- Rounding of numeric results compared to the full stored precision: an OOS decision must not change because of a display rounding difference.
- Audit-trail entries compared for presence, attributability and content.

Exit criteria

- Zero unexplained mismatches on HIGH-tier endpoints over the full shadow period.
- Every mismatch either resolved or accepted with a documented justification approved by QA.
- Performance of the new service within the agreed envelope under production-equivalent load.

6. Data migration checks

0 of 0 table(s) in scope hold regulated records.

- Run every check on a full-volume copy of production data before the live cutover.
- Record the verification output as system-generated evidence; a reported count is not evidence.
- Reconcile again immediately after cutover, before the system is released for use.
- Retain the reconciliation reports for the record retention period.

7. Traceability matrix

3 requirement-to-evidence link(s), derived from the GxP criticality analysis.

ID	Requirement	Component	Tier	Test approach
URS-INT-001	GxP records shall be complete, accurate and attributable throughout their lifecycle.	ProductBatch	**MEDIUM**	Unscripted / exploratory testing with recorded results
URS-INT-002	GxP records shall be complete, accurate and attributable throughout their lifecycle.	TestResult	**MEDIUM**	Unscripted / exploratory testing with recorded results
URS-TIM-003	GxP records shall be time-stamped from a single authoritative, synchronised time source.	DateHelper	**MEDIUM**	Unscripted / exploratory testing with recorded results

8. Rollback plan

Trigger criteria

- Any mismatch on a HIGH-tier function that cannot be explained within the cutover window
- Any GxP record written without a corresponding audit-trail entry
- Data-migration reconciliation failing after cutover
- Loss of attributability for any write (an actor cannot be resolved)
- Performance outside the agreed envelope such that operations cannot proceed

Procedure

- Stop new work entering the modernized component; queue inbound requests.
- Re-point the facade or API gateway to the legacy implementation.
- Export every record created or modified in the modernized component since cutover, with its audit trail.
- Reconcile and replay those records into the legacy system under change control - they are GxP records and may not be discarded.
- Verify audit-trail continuity across both the cutover and the rollback.
- Raise a deviation, perform the investigation, and record the root cause.

Regulated data created after cutover

Records created in the modernized component between cutover and rollback are regulated records. They must be preserved, reconciled into the system of record, and their audit trail must remain continuous and attributable across both transitions. Plan the export path before cutover, not during the incident.

Rollback window: Rollback must remain possible for at least one full business cycle after cutover; keep the legacy path warm and tested for that period.

Decision authority: System owner plus QA; for HIGH-tier components the Qualified Person is informed before any rollback of a release path.

9. Cloud supplier oversight checklist

EU GMP Annex 11 draft (July 2025) addresses cloud and service providers explicitly; 21 CFR Part 11 expectations for records held by a third party continue to apply to the regulated company.

Item	What is required	Owner	When
Supplier assessment completed and approved	Formal assessment of AWS covering quality system, certifications (ISO 27001, SOC 2), and relevant audit reports.	QA / Procurement	Required before cutover
Quality or service agreement in place	Written agreement defining GxP responsibilities, notification of change, incident reporting, data-return and exit terms.	QA / Legal	Required before cutover
Responsibility split documented (shared responsibility model)	Explicit allocation for each control: infrastructure, platform patching, backup, restore testing, access management, monitoring, and qualification evidence.	IT / QA	Required before cutover
Data residency confirmed and pinned	Region pinned for primary, replica and backup copies of regulated data; cross-border transfer assessed and documented.	IT / Regulatory	Required before cutover
Backup and restore qualified	Backup schedule, retention aligned to record retention, and a documented restore test with evidence - a backup that has never been restored is not a control.	IT	Required before cutover
Access management and privileged access reviewed	Named individual accounts, least privilege, MFA, periodic access review, and logging of provider personnel access to regulated data.	Security / QA	Required before cutover
Change notification and change control	Process for assessing provider-initiated changes against validated state, including deprecation notices.	QA / IT	Ongoing
Business continuity and exit strategy	Documented continuity plan, and an exit plan demonstrating regulated records can be retrieved in a readable form for their full retention period.	IT / QA	Required before cutover
Periodic review scheduled	Defined frequency for re-assessing the supplier and reviewing performance, incidents and changes.	QA	Ongoing

Annex A - Modernization decisions in this wave

Cluster	Strategy	Conf.	Effort (wks)	Rationale
cluster:5	**Replatform**	63%	2.14/2.74/4.11	ProductBatch, BatchMapper is coupled to an end-of-life runtime. Replatforming onto containers with a managed database removes the operational risk with no functional change, which is validatable as an infrastructure qualification rather than a full re-validation. Security Officer argued for Rehost; that position is recorded as dissent.
cluster:6	**Replatform**	63%	2.16/2.77/4.16	TestResult, TestResultMapper is coupled to an end-of-life runtime. Replatforming onto containers with a managed database removes the operational risk with no functional change, which is validatable as an infrastructure qualification rather than a full re-validation. Security Officer argued for Rehost; that position is recorded as dissent.
cluster:7	**Replatform**	72%	2.15/2.76/4.14	StringHelper, DateHelper is coupled to an end-of-life runtime. Replatforming onto containers with a managed database removes the operational risk with no functional change, which is validatable as an infrastructure qualification rather than a full re-validation. Security Officer argued for Rehost; that position is recorded as dissent.
cluster:8	**Retire**	90%	0.44/0.52/0.7	LegacyExcelExporter has no inbound calls and no runtime hits across the traced use cases, so it is retired rather than migrated.

Recorded dissent - cluster:5

Agent	Position	Reason
Security Officer	Rehost	Cloud Architect (Replatform), Validation & QA Lead (Replatform), FinOps Analyst (Retain) differ on strategy, which does not affect my position: my conditions attach to whichever option is chosen. I will rank them - no blocking finding is the one that must precede any migration. No blocking security
FinOps Analyst	Retain	Cloud Architect (Replatform), Validation & QA Lead (Replatform), Security Officer (Rehost) disagree. I have weighed their arguments and hold my position. Only 0 runtime hits across the traced period. There is no cost of delay here. Spend the wave-1 budget on the high-traffic paths and revisit this w
Regulatory Affairs	Rehost	Cloud Architect (Replatform), Validation & QA Lead (Replatform), FinOps Analyst (Retain) differ on strategy. My obligations are sequenced, not blocking: the supplier assessment must exist before cutover, the residency documentation can run concurrently. No GxP records in this cluster, so no supplier

Recorded dissent - cluster:6

Agent	Position	Reason
Security Officer	Rehost	Cloud Architect (Replatform), Validation & QA Lead (Replatform), FinOps Analyst (Retain) differ on strategy, which does not affect my position: my conditions attach to whichever option is chosen. I will rank them - no blocking finding is the one that must precede any migration. No blocking security
FinOps Analyst	Retain	Cloud Architect (Replatform), Validation & QA Lead (Replatform), Security Officer (Rehost) disagree. I have weighed their arguments and hold my position. Only 0 runtime hits across the traced period. There is no cost of delay here. Spend the wave-1 budget on the high-traffic paths and revisit this w
Regulatory Affairs	Rehost	Cloud Architect (Replatform), Validation & QA Lead (Replatform), FinOps Analyst (Retain) differ on strategy. My obligations are sequenced, not blocking: the supplier assessment must exist before cutover, the residency documentation can run concurrently. No GxP records in this cluster, so no supplier

Recorded dissent - cluster:7

Agent	Position	Reason
Security Officer	Rehost	Cloud Architect (Replatform), Validation & QA Lead (Replatform), FinOps Analyst (Replatform) differ on strategy, which does not affect my position: my conditions attach to whichever option is chosen. I will rank them - no blocking finding is the one that must precede any migration. No blocking secur
Regulatory Affairs	Rehost	Cloud Architect (Replatform), Validation & QA Lead (Replatform), FinOps Analyst (Replatform) differ on strategy. My obligations are sequenced, not blocking: the supplier assessment must exist before cutover, the residency documentation can run concurrently. No GxP records in this cluster, so no supp

Annex B - Review and approval

This pack is a draft. Signing below records that the named reviewer has assessed its content for this wave.

Role	Name	Signature	Date
Prepared by (ModernRx)	Automated draft	n/a	2026-10-13
Reviewed by (System owner)			
Approved by (QA)			
Noted by (Qualified Person)			